CSA6303- Threat Intelligence and Network Security

AT1: Application-Based Questions

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats |Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan **Total: 50**

Student Name : G. Aswartha Manidheep **Register number: 192425089**

Code of Conduct:

I G. Aswartha Manidheep (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student

AT1: Application-Based Questions

Q1.CIA Triad — Scenario Identification (5 marks)
An e-commerce site stays fully online during an incident, but customers notice product prices have been silently changed by an attacker who gained database write access. No downtime occurred. Which CIA Triad principle(s) are violated? Justify your answer

Q2. Risk Quantification — Annualized Loss Expectancy (10 marks)
A company's customer database is valued at $50,000. A breach would destroy/corrupt 40% of its value (Exposure Factor). Historical data shows this type of breach occurs about twice a year (Annualized Rate of Occurrence = 2). Calculate the Single Loss Expectancy (SLE) and the Annualized Loss Expectancy (ALE). Show all formulas used.

Q3. Brute-Force Attack Time Estimation (10 marks)
An 8-character password uses a 62-character set (a-z, A-Z, 0-9). An attacker's cracking rig tests 1 billion passwords per second. Calculate the size of the keyspace and the worst-case time required to exhaust it. Express your answer in hours.

Q4. Risk Prioritization Matrix (10 marks)
Given five threats rated on Likelihood (1-5) and Impact (1-5), compute the Risk Score (Likelihood x Impact) for each and rank them in order of patching/budget priority:
(a) Ransomware — L4, I5;
(b) Phishing — L5, I3;
(c) Insider data theft — L2, I5;
(d) DDoS — L3, I3;
(e) Unpatched server exploit — L4, I4.

Q5. Passive vs. Active Threat Classification (5 marks)
Classify each of the following as a passive or active threat, and state which CIA principle it primarily threatens:
(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.
(b) An attacker performing ARP spoofing to redirect traffic.
(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Q6. Threat Intelligence Lifecycle sequencing (10 marks)
A SOC analyst receives an executive request: "Are we at risk from the ransomware group currently targeting our industry?" Arrange the following into the correct order of the Threat Intelligence Lifecycle, and name each phase:

(i) Analysts correlate collected IOCs with internal logs.
(ii) A report is sent to the CISO.
(iii) The request itself is logged as a requirement.
(iv) OSINT and threat feeds are pulled for the group's known TTPs.
(v) The CISO's follow-up questions shape the next collection cycle.

CSA6303 - Threat Intelligence and Network Security

AT1: Application-Based Questions - Answer Key (CO1)

Q1. CIA Triad - Scenario Identification (5 marks)

Answer: **Integrity** is violated.

Justification:

- Integrity means data stays accurate and is changed only by authorized parties. The attacker used database write access to silently change product prices, so the data is no longer trustworthy.

- **Availability is NOT violated**: the site stayed fully online and no downtime occurred.

- **Confidentiality is not the primary issue**: the scenario describes modification, not disclosure of data. (Gaining database access implies a possible access-control failure, but no data leak is described.)

- Business impact: wrong prices cause financial loss, customer disputes and reputational damage, and the attack is hard to detect because everything appears to work normally. Controls: least-privilege DB access, hashing/checksums, audit logging, change monitoring, and backups.

Q2. Risk Quantification - ALE (10 marks)

Given: Asset Value (AV) = $50,000; Exposure Factor (EF) = 40% = 0.40; ARO = 2

Formulas:

```
SLE = AV x EF
ALE = SLE x ARO
```

Step 1 - SLE:

```
SLE = $50,000 x 0.40 = $20,000
```

Step 2 - ALE:

```
ALE = $20,000 x 2 = $40,000 per year
```

Interpretation: the company can expect to lose about $40,000 per year from this threat, so a control costing less than $40,000 per year that eliminates the risk would be cost-justified.

Q3. Brute-Force Attack Time Estimation (10 marks)

Given: length L = 8; character set size N = 62; attack rate = 1×10^9 passwords/second

Step 1 - Keyspace = N^L

Keyspace = 62^8 = **218,340,105,584,896** (approx. 2.18×10^{14})

Step 2 - Worst-case time (all combinations tested)

Time (s) = 218,340,105,584,896 / 10^9 = 218,340.1 seconds

Step 3 - Convert to hours

Time (h) = 218,340.1 / 3600 = **approx. 60.65 hours**

That is about 2.5 days in the worst case (on average, the password is found after half the keyspace, about 30.3 hours).

Q4. Risk Prioritization Matrix (10 marks)

```
Risk Score = Likelihood x Impact
```

Threat	L	I	Risk Score (L x I)	Rank
Ransomware	4	5	4 x 5 = **20**	1

Threat	L	I	Risk Score (L x I)	Rank
Unpatched server exploit	4	4	4 x 4 = **16**	2
Phishing	5	3	5 x 3 = **15**	3
Insider data theft	2	5	2 x 5 = **10**	4
DDoS	3	3	3 x 3 = **9**	5

Priority order (patching/budget): Ransomware (20) > Unpatched server exploit (16) > Phishing (15) > Insider data theft (10) > DDoS (9).

Notes: the unpatched server exploit is cheap to fix by patching, and it is often the entry point for ransomware, so it should be addressed immediately alongside ransomware defenses (backups, EDR). Insider theft has low likelihood but high impact, so it still deserves monitoring and access controls even though it ranks lower.

Q5. Passive vs. Active Threat Classification (5 marks)

Scenario	Type	Primary CIA principle	Reason
(a) Sniffing unencrypted traffic on public Wi-Fi	**Passive**	**Confidentiality**	Attacker only observes data; nothing is altered, but contents are exposed.
(b) ARP spoofing to redirect traffic	**Active**	**Integrity**	Attacker forges ARP replies and manipulates traffic flow (man-in-the-middle), enabling modification or interception. (Confidentiality is also at risk, but the manipulation of data/traffic is the primary violation.)
(c) Nation-state long-term reconnaissance without altering anything	**Passive**	**Confidentiality**	Gathers information silently; no modification of systems or data.

Q6. Threat Intelligence Lifecycle Sequencing (10 marks)

Correct order: (iii) > (iv) > (i) > (ii) > (v)

Step	Item	Lifecycle Phase	Explanation
1	(iii) The request is logged as a requirement	**Planning & Direction**	The executive question defines the intelligence requirement and scope.
2	(iv) OSINT and threat feeds pulled for the group's TTPs	**Collection**	Raw data is gathered from external sources.
3	(i) Analysts correlate collected IOCs with internal logs	**Processing & Analysis**	Data is normalized and correlated with internal telemetry to determine whether the organization is actually exposed or compromised.
4	(ii) Report sent to the CISO	**Dissemination**	Finished intelligence is delivered to the decision-maker.
5	(v) CISO's follow-up questions shape the next collection cycle	**Feedback**	Consumer feedback refines requirements and restarts the cycle.

Lifecycle summary: Planning & Direction > Collection > Processing > Analysis > Dissemination > Feedback (cyclical). Here, Processing and Analysis are combined in item (i).